

자산분석 및 위험관리 지침



주식회사 모인

개정 이력

[illegible]

자산 분석 및 위험관리 지침

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 지침은 주식회사 모인(이하 "회사"라 한다)의 모든 정보시스템 및 시설을 대상으로 하고 있으며, 주요 자산을 식별하여 평가하고 자산의 훼손, 위·변조, 도난 유출 등의 다양한 형태의 위험을 식별하여 자산을 비용 대비 효과적으로 보호하기 위함을 목적으로 한다.

제2조(적용 범위) 이 지침은 회사의 정보시스템과 이의 개발, 운영 및 유지보수에 관련된 시설, 정보 및 데이터, 문서 등 회사 내부의 모든 자산을 대상으로 하며, 이를 관리 및 사용하는 모든 임직원을 대상으로 한다.

제3조(용어의 정의) 이 지침은 다음 용어 정의를 따른다.

1. "자산"이란 회사가 보유하고 있는 가치를 지닌 것으로서, 서버, 네트워크, DBMS, 정보보호시스템, 소프트웨어, 전자정보, 문서, 단말기, 인적 자산, 물리적 자산이 포함되며, 이에 국한되지 않는다.
2. "전산자료"라 함은 전산장비에 의해 입력·보관·출력되어 있는 자료를 말하며 그 자료가 입력·출력되어 있는 자기테이프, 디스크, 디스켓, 콤팩트디스크(CD) 등 보조기억매체를 포함한다.
3. "기밀성"이란 비 인가자가 임의의 정보를 사용하거나 정보가 노출되지 못하도록 하는 특성을 말하며, 자산 또는 데이터가 전송, 백업, 보관 중에 허가 받지 않은 사람에게 노출되지 않아야 함을 의미한다.
4. "무결성"이란 비인가 된 방법을 통해 정보를 변경 또는 파괴하지 못하도록 하는 특성을 말하며, 정보가 전송되고 저장되는 과정에서 완전성과 정확성을 유지하는 것을 의미한다.
5. "가용성"이란 권한을 가진 개체의 요구에 따라 회사의 자산을 지속적으로 접근하고 사용이 가능하도록 하는 특성을 의미한다.
6. "취약점"이란 회사의 자산이 가지고 있는 약점들로서, 바이러스 패치의 부족, 소프트웨어의 테스트 부족, 패스워드 및 네트워크 접근 설정의 부재 등과 같이 자산에 직접적인 해는 없으나 위협에 의해 자산에 손실을 입을 수 있는 상황을 의미하며, 자산에 대한 통제(보안 대책)를 적용하여 취약점 수준을 감소시키거나 제거가 가능하다.
7. "위협"이란 원치 않은 사건을 야기하여 회사의 자산에 손실을 줄 수 있는 잠재성을 가지고 있는 것을 의미하며, 바이러스, 해킹, 소프트웨어의 장애 등이 해당된다.
8. "위험"이란 자산에 존재하는 취약점을 이용하여 발생할 수 있는 위협을 의미하며, 자산의 중요성에

따라서 그 위험의 크기는 변할 수 있다.

9. "위험평가란 자산의 중요도와 자산의 기밀성, 무결성, 가용성 측면에서의 취약점 수준에 따라 위험의 크기를 측정하고, 위험도를 산출한 뒤, 위험 수준을 결정하여 위험관리 목표에 따라 위험관리 방법의 적정성과 잔여위험의 수용 여부에 대하여 결정하는 것을 의미한다.
10. "수용 가능한 위험 수준(Degree of Assurance, DoA)"이란 위험분석 결과 나타난 보안관리체계 범위 내의 자산 별 위험에 대하여 수용 가능한 위험도의 수준을 결정하는 것을 의미한다(예를 들어 3~9점까지의 위험도 중에서, 4점 이하의 위험도를 가지는 위험을 수용하기로 결정되었다면 DoA는 4점 이하가 된다).
11. "관리대상 위험"이란 위험분석 결과 나타난 보안관리체계 범위 내의 자산 별 위험 중 수용 가능한 위험도의 수준을 넘어서는 것으로 파악되어, 위험을 수용하는 것이 아니라 위험을 감소시켜야 하는 것으로 결정된 위험을 의미한다.

제2장 역할 및 책임

제4조(정보보호최고책임자)

- 1 정보보호최고책임자(이하 “CISO”라 한다)는 자산관리, 위험평가 등 관련 업무 담당자의 업무 수행을 총괄한다.
- 2 CISO는 자산관리대장, 위험평가, 위험관리계획에 대한 최종 책임을 갖는다.

제5조(정보보호 담당자)

- 1 정보보호 담당자는 정보보안 정책/기술 담당자로서 자산에 대한 분류기준 수립, 위험 등급, 위험도 산정, 위험관리 방안, 위험평가 결과 작성 등의 업무를 담당한다.
- 2 정보보호 담당자는 실무담당자들을 통해 취합된 자산관리대장을 관리하고 주기적으로 검토하여 최신으로 관리할 책임을 갖는다.
- 3 정보보호 담당자는 식별된 자산에 대하여 위험평가를 수행할 책임이 있으며, 그 결과를 CISO에게 보고하여야 한다. 다만, 위험평가 수행 시 자산의 위험 식별 및 위험관리 방안 수립을 위하여 실무담당자의 협조를 요청할 수 있다.
- 4 정보보호 담당자는 단계별 위험관리 방안에 따라 위험관리의 적절성을 점검하기 위한 사후 점검을 실시할 책임을 갖는다.

제6조(실무담당자)

- 1 실무담당자는 각 팀에서 보유하고 있는 자산의 식별, 중요도 평가, 위험식별 업무를 수행하는 등의 각 팀 내 실무 업무를 담당한다.

- 2 실무담당자는 자신의 해당 팀에서 관리하는 자산을 식별하고 관리해야 할 책임을 갖는다.
- 3 실무담당자는 정보보호 담당자의 위험평가 수행 시 관리하고 있는 자산에 대하여 위험 식별 및 위험관리 방안 수립을 지원하여야 한다.

제3장 자산 분석 및 위험관리

제7조(자산 분석 및 위험관리 절차)



- 1 회사의 자산 분석 및 위험관리 절차는 다음 각 호와 같이 5단계로 구성된다.
 - 1) 자산분석: 관리되어야 할 자산 파악 및 중요도 평가 수행
 - 2) 위험식별: 자산에 대한 위험 및 취약성 식별
 - 3) 위험분석: 위험 및 취약성에 따른 위험 식별
 - 4) 위험평가: 자산에 대한 위험평가 수행
 - 5) 위험관리: 도출된 위험에 대한 위험관리 계획 수립 등 관리방안 마련
- 2 정보보호 담당자는 식별된 자산에 대해 중요도를 고려하여 연 1회 이상 위험평가를 실시하고 그 결과를 CISO에게 보고하여야 한다.
- 3 위험수용 내역이 포함된 위험평가 결과 및 위험관리 계획은 정보보호위원회에서 심의·의결하여야 한다.
- 4 회사의 정보보호관리체계를 구성하는 환경의 중대한 변화가 발생되었을 경우 CISO의 결정에 따라 위험평가를 추가로 실시할 수 있다.

제8조(자산분석)

- 1 실무담당자는 관리하는 자산을 파악하고 보호하여야 할 자산을 식별하여야 하며, 기존의 자산 뿐만 아니라 새로 도입하거나 변경, 폐기하는 자산도 식별하여 관리하여야 한다.
- 2 실무담당자는 식별된 자산에 대해 중요도를 평가하여 자산관리대장에 기록하고 정보보호 담당자에게 보고하여야 한다.
- 3 정보보호 담당자는 실무담당자가 제출한 자산관리대장의 중요도 평가결과를 검토하여 자산의 보안등급을 조정하고, 자산관리대장을 취합하여 관리하여야 한다.
- 4 정보보호 담당자는 연 1회 이상 자산 조사를 실시하여 미등록 자산 및 등록된 용도와 다른 용도로

활용되는 자산을 식별 및 자산관리대장에 기록하여 CISO에게 보고하여야 한다.

제9조(위험식별)

- 1 정보보호 담당자는 자산관리대장에 등록되어 있는 자산에 대하여 실무담당자의 협조를 받아 발생 가능한 위험과 자산에 존재하는 취약성을 식별하여야 한다.
- 2 정보보호 담당자는 식별된 위험과 취약성에 대하여 발생 가능성과 업무에 미치는 영향도를 판단하여 위험·취약성 등급을 산정하여야 한다.

제10조(위험분석)

- 1 정보보호 담당자는 자산 분석 및 위험식별 결과를 바탕으로 자산에 대한 위험을 분석하고 위험도를 산정하여야 한다.
- 2 위험도는 다음 각 호의 분석 기법에 따라 자산별 특성을 반영하여 자산의 가치 및 위험·취약성 결과에 따라 위험도를 세부적으로 산정하여야 한다.
 - 1) 기준선 접근법(Baseline Approach)
 - 2) 상세위험 접근법(Detailed Risk Approach)
 - 3) 복합적 접근법(Combined Approach)
 - 4) 전문가 판단법(Informal Approach)

제11조(위험평가)

- 1 정보보호 담당자는 위험분석 결과를 바탕으로 수용 가능한 위험수준(DoA: Degree of Assurance)를 결정하고, 이를 기반으로 관리대상 위험을 식별하여 위험관리 목표를 설정하여야 한다.
- 2 수용 가능한 위험수준은 비용 대비 효과, 투입 인력 및 소요 시간 등을 고려하여 수립하여야 한다.

제12조(위험관리)

- 1 정보보호 담당자는 도출된 위험관리 목표에 따라 위험관리 방법 및 다음 각 호의 단계별 위험관리 방안을 위험관리 계획서에 작성하여야 한다.
 - 1) 위험감소(Mitigation): 위험을 감소시킬 수 있는 대책을 마련하여 구현
 - 2) 위험회피(Avoidance): 위험이 존재하는 자산을 제거
 - 3) 위험수용(Acceptance): 위험을 받아들이고 잠재적 손실 비용을 감수
 - 4) 위험전가(Transfer): 보험이나 외주 등으로 잠재적 비용을 제3자에게 이전
- 2 위험의 시급성, 효과성 및 적용 용이성을 고려한 우선순위를 정의하여 위험관리 계획을 수립하여야 한다.
- 3 위험관리 방법 중 위험수용의 경우 실무담당자와 정보보호 담당자가 서비스 영향도, 보안 통제 방안

등을 고려하여 위험수용으로 분류하고, 위험수용에 따른 대체통제 방안을 마련하여야 한다.

- 4 정보보호 담당자는 위험수용의 사유 및 대체통제 방안을 위험관리 계획서에 포함하여 CISO에게 보고하고, 정보보호위원회의 심의·의결을 통해 대표이사의 승인을 득하여야 한다.

제13조(사후관리)

- 1 정보보호 담당자는 위험관리의 적절성을 점검하기 위하여 위험관리 계획 이행여부에 대한 사후점검을 실시하여야 한다.
- 2 정보보호 담당자는 사후점검결과를 CISO 및 대표이사에게 보고하여야 한다.

제14조 (전산자료 보호대책)

- 1 전산자료의 유출, 파괴 등을 방지하기 위하여 다음 각 호를 포함한 전산자료 보호대책을 수립·운용하여야 한다.
 - 1) 전산자료의 보유현황을 관리하고 관리책임자를 지정·운영한다.
 - 2) 전산자료 및 전산장비의 반출·입을 통제한다.
 - 3) 비상 시에 대비하여 보조기억매체 등 전산자료에 대한 안전지출 및 긴급파기 계획을 수립·운용한다.
 - 4) 정기적으로 보조기억매체의 보유 현황 및 관리실태를 점검하고 관리책임자의 확인을 받도록 한다.
 - 5) 중요도에 따라 전산자료를 정기 백업 및 안전지역(원격지를 말한다)에 소산하고 백업내역을 기록·관리한다.
 - 6) 주요 백업 전산자료에 대한 정기적인 검증을 실시해야 한다.
 - 7) 이용자정보의 조회·출력 통제 및 테스트 시 주요 이용자정보를 변환하여 사용한다.
 - 8) 정보처리시스템 가동기록은 1년 이상 보존할 것
 - 9) 정보처리시스템에 접근 시 일정횟수 이상 접속 오류가 발생하는 경우 정보처리시스템의 사용을 제한해야 한다.
 - 10) 개인용컴퓨터(PC)에 중요 전산자료를 보관하지 아니하고, 개인용컴퓨터를 공유하지 아니할 것(다만 불가피하게 개인용컴퓨터에 보관할 필요가 있는 경우에는 보관사유·보관기간 및 관리 비밀번호 등을 정하여 책임자 승인을 받을 것)
- 2 사용자계정의 공동 사용이 불가피한 경우에는 개인별 사용내역을 기록·관리하여야 한다.
- 3 단말기를 통한 이용자정보 조회 시 사용자, 사용 일시, 변경 또는 조회내용, 접속방법 등이 정보처리시스템에 자동 기록되도록 하고, 그 기록을 1년 이상 보존하여야 한다.
- 4 제1항 제8호의 정보처리시스템 가동기록의 경우 다음 각 호의 사항이 자동 기록되도록 하되 접속의 성공여부와 상관없이 기록·유지하며 정기적으로 관리책임자에게 보고하여야 한다.
 - 1) 주전산기 또는 서버에 접속한 일시, 접속자 및 접근을 확인할 수 있는 접근기록

- 2) 전산자료를 사용한 일시, 사용자 및 자료의 내용 등을 확인할 수 있는 접근기록
 - 3) 정보처리시스템 접근을 위한 사용자 로그인, 액세스 로그 등 자료처리 내용을 확인할 수 있는 접근기록
- 5 단말기와 전산자료의 접근권한이 부여되는 마스터관리자에 대하여 적절한 통제장치를 마련·운용하여야 한다.

부칙

제1조(시행일) 이 지침의 시행일은 대표이사가 승인한 날로 한다.